

إجراءات تشغيل الأمان

اسم الإجراء	إجراءات التشغيل الأمنية لإدارة تقنية المعلومات
-------------	--

النسخة	تمت الموافقة عليها	المالك	تاريخ آخر تحديث	تكرار المراجعة	المراجعة القادمة	تعليقات
1.0	د/نورا القحطاني - CEO	سارة الحربي - CISO	2026/09/12	سنوياً	2027 سبتمبر 19	إجراءات تشغيل أمنة مقترحة لإدارة أنظمة تقنية المعلومات في بنك الأفاق الرقمية، مبنية على الوضع الحالي الوارد في دراسة الحالة ومتطلبات ISO/IEC 27001:2022

التصنيف: سري

يجب أن يقتصر هذا المستند على من لديهم حاجة محددة.

1. الغرض

تهدف هذه الإجراءات إلى تنظيم وتوحيد العمليات التشغيلية المتعلقة بإدارة أنظمة تقنية المعلومات وحمايتها في بنك الأفاق الرقمية، بما يدعم سرية المعلومات وسلامتها وتوفرها، ويقلل من مخاطر الأخطاء البشرية، والتغييرات غير المنضبطة، والثغرات الأمنية، وسوء استخدام الصلاحيات. كما تهدف إلى ضمان تنفيذ العمليات التشغيلية بطريقة آمنة وموثوقة وقابلة للمراجعة، بما يتوافق مع متطلبات نظام إدارة أمن المعلومات ISO/IEC 27001:2022 ، وبالأخص الضابط A.5.37 الخاص بإجراءات التشغيل الموثقة.

2. النطاق

تتطبق هذه الإجراءات على أنظمة وخدمات تقنية المعلومات الواقعة ضمن نطاق نظام إدارة أمن المعلومات في بنك الأفاق الرقمية، وتشمل الخوادم، أجهزة الموظفين، أنظمة Active Directory، قواعد البيانات، تطبيق آفاق بلس، منصة آفاق نت، أنظمة الشبكات وجدران الحماية، أنظمة IDS/IPS، نظام Trend Micro، نظام Syslog، منصة Qualys لإدارة وفحص الثغرات، الشهادات الرقمية، وبيئات التطوير والاختبار والإنتاج.

كما تشمل فرق تقنية المعلومات، أمن المعلومات، مركز العمليات الأمنية SOC، فريق الاستجابة للحوادث، وفريق تقييم المخاطر والثغرات، ومالكي الأنظمة ذوي العلاقة.

3. الأدوار والمسؤوليات

Responsibility	Role
الإشراف على تطبيق الإجراءات الأمنية، اعتماد المتطلبات الأمنية، ومتابعة الالتزام.	CISO
الإشراف على العمليات التقنية وتوفير الموارد والتنسيق بين فرق تقنية المعلومات والأمن.	CIO / IT Manager
إدارة الأنظمة والشبكات وتنفيذ التغييرات والإعدادات والنسخ الاحتياطي والاستعادة وفق الإجراءات المعتمدة.	IT Infrastructure / Network Team
مراقبة الأحداث والسجلات الأمنية، تحليل التنبيهات، واكتشاف الحوادث الأمنية ورفعها.	SOC / Information Security Team
تنفيذ ومتابعة فحوصات الثغرات باستخدام Qualys ، وتوثيق نتائج المعالجة والتحقق منها.	Risk & Vulnerability Assessment Team
مراجعة واعتماد التغييرات الخاصة بالأنظمة التابعة لهم والتأكد من الالتزام بالمتطلبات الأمنية.	System Owners
الالتزام بالإجراءات الأمنية والإبلاغ عن الحوادث والأنشطة المشبوهة وفق القنوات المعتمدة.	All Employees

4. الإجراءات

الخطوة الأولى: Access and Account Management

تتم إدارة حسابات المستخدمين والصلاحيات باستخدام Microsoft Active Directory. يجب أن يكون لكل مستخدم حساب شخصي، وتمنح الصلاحيات وفق الحاجة الوظيفية ومبدأ Least Privilege. تتم مراجعة الصلاحيات بشكل دوري، وإزالة الصلاحيات غير الضرورية عند تغيير وظيفة المستخدم أو انتهاء علاقته بالبنك. يمنع استخدام الحسابات الإدارية المشتركة، ويجب أن تكون الأنشطة المرتبطة بالحسابات المميزة قابلة للتنبع.

الخطوة الثانية: Secure Configuration Management

يجب تطبيق إعدادات الأمان المعتمدة في Secure Configuration Baseline على الأنظمة والأجهزة المشمولة. وتشمل الإعدادات الأمنية، حسب نوع النظام، التشفير، Firewall، التحديثات الأمنية، الحماية من البرمجيات الخبيثة، إعدادات المصادقة، تسجيل الأحداث، وتعطيل الخدمات غير الضرورية. يجب توثيق أي استثناء عن خط الأساس الأمني والحصول على الموافقة المناسبة.

الخطوة الثالثة: Patch and Vulnerability Management

يتم استخدام منصة Qualys لفحص الثغرات الأمنية في الأنظمة المشمولة. تسجل نتائج الفحص ويتم تصنيف الثغرات حسب مستوى الخطورة والأولوية. يتم تحديد مالك لكل ثغرة وخطة لمعالجتها، ثم يتم التحقق من نجاح المعالجة وإعادة الفحص عند الحاجة. تعطى الثغرات ذات الخطورة العالية أولوية مرتفعة.

وهذا مرتبط مباشرة بحالة البنك التي تضمنت نتائج فحص للثغرات، منها 3 High في تطبيق آفاق بلس و 7 Medium في الخدمات المصرفية الإلكترونية و 5 Medium في الشبكة الداخلية و 12 Low، مع بقاء معظم الثغرات المتوسطة دون معالجة.

الخطوة الرابعة: Change Management

يجب تسجيل التغييرات المخطط لها قبل تنفيذها، مع تحديد النظام المتأثر، سبب التغيير، المخاطر المحتملة، وخطة الاختبار وخطة التراجع Rollback. يجب اعتماد التغييرات وفق الصلاحيات المحددة. بالنسبة للتغييرات الحرجة في إعدادات الشبكة و Firewall، يقترح فريق المشروع تطبيق مراجعة ثنائية قبل التنفيذ، مع الاحتفاظ بنسخة احتياطية من الإعدادات واختبار التغيير قبل تطبيقه في بيئة الإنتاج.

الخطوة الخامسة: Encryption and Endpoint Protection

يجب استخدام Full-Disk Encryption على الأجهزة التي تخزن أو تعالج بيانات البنك الحساسة، وفق Secure Configuration Baseline المعتمد. كما يجب المحافظة على Trend Micro وحالة الحماية الأمنية على الأجهزة والأنظمة المشمولة، مع إجراء مراجعات دورية للتأكد من الالتزام.

وهذه النقطة تعالج حادثة الجهاز المحمول المفقود الذي كان يحتوي على بيانات عملاء وكان غير مشفر.

الخطوة السادسة: Production and Test Environment

يجب فصل بيئات الإنتاج عن بيئات التطوير والاختبار. يمنع استخدام بيانات العملاء الحقيقية في بيئة الاختبار إلا في حالات معتمدة ووفق ضوابط حماية مناسبة. يجب استخدام بيانات اختبار مناسبة أو إخفاء البيانات الحساسة عند الحاجة.

هذه النقطة مهمة جداً لأن دراسة الحالة ذكرت استخدام بيانات حقيقية في بيئة الاختبار كفجوة مرتبطة بالضوابط A.8.11 و A.8.31 و A.8.33.

الخطوة السابعة: Logging and Monitoring

يتم جمع السجلات الأمنية وسجلات الأحداث من الأنظمة والأجهزة ذات الصلة باستخدام Syslog. يقوم فريق SOC وأمن المعلومات بمراجعة السجلات والتنبيهات وفق إجراءات المراقبة المعتمدة، وتوثيق الأحداث الأمنية المهمة. لا يفترض هذا الإجراء وجود SIEM حاليًا، حيث تشير دراسة الحالة إلى أن تحليل السجلات يتم يدويًا.

الخطوة الثامنة: TLS/SSL Certificate Management

يجب الاحتفاظ بسجل للشهادات الرقمية المستخدمة في الأنظمة والخدمات، يتضمن اسم الشهادة، النظام المرتبط بها، المالك، تاريخ الإصدار وتاريخ انتهاء الصلاحية. يقترح فريق المشروع تطبيق تنبيهات آلية قبل انتهاء الشهادات، مع إجراء مراجعة دورية للسجل.

هذه الخطوة مرتبطة بحادثة انتهاء شهادة TLS/SSL التي استمرت دون اكتشاف لمدة 4 ساعات.

الخطوة التاسعة: Backup and Recovery

يتم تحديد الأنظمة والبيانات التي تحتاج إلى نسخ احتياطية بناءً على أهميتها ونتائج تقييم المخاطر وخطة استمرارية الأعمال والتعافي من الكوارث. يجب حماية النسخ الاحتياطية وتقييد الوصول إليها، كما يجب اختبار عمليات الاستعادة بشكل دوري. يتم تحديد RTO و RPO واعتمادهما من خلال Business Impact Analysis وخطة BCP/DR.

مهم: لا تضعي أرقام RTO/RPO من عندك على أنها موجودة في دراسة الحالة؛ الدراسة لم تحددتها.

الخطوة العاشرة: Incident Reporting

عند اكتشاف حادث أمني، مثل فقدان جهاز، وصول غير مصرح به، تصيد، برمجة خبيثة، تغيير غير مصرح به، أو خلل في إعدادات الشبكة، يجب الإبلاغ فورًا إلى SOC أو Information Security وفق آلية الإبلاغ المعتمدة. يجب المحافظة على السجلات والأدلة ذات الصلة، وتوثيق إجراءات الاحتواء والمعالجة والاستعادة والسبب الجذري للحادث.

الخطوة الحادي عشرة: Documentation

يجب توثيق العمليات والتغييرات ونتائج فحوصات الثغرات والاستثناءات والحوادث وإجراءات المعالجة والمراجعات الأمنية. تحفظ الوثائق بطريقة آمنة، ويقتصر الوصول إليها على الأشخاص المخولين.

5. ضوابط الأمان

Application	Name	Control
توثيق إجراءات التشغيل الآمن ومراجعتها وتحديثها.	Documented Operating Procedures	A.5.37
إدارة الوصول إلى الأنظمة والمعلومات وفق الحاجة الوظيفية.	Access Control	A.5.15
مراجعة وتعديل وإلغاء حقوق الوصول.	Access Rights	A.5.18
حماية وإدارة صلاحيات المسؤولين ومنع الحسابات الإدارية المشتركة.	Privileged Access Rights	A.8.2
فحص الثغرات ومعالجتها والتحقق من إغلاقها.	Management of Technical Vulnerabilities	A.8.8
تطبيق ومراجعة Secure Configuration Baseline.	Configuration Management	A.8.9
حماية البيانات الحساسة عند استخدامها في الاختبار عند الحاجة.	Data Masking	A.8.11
جمع وحماية سجلات الأحداث.	Logging	A.8.15
مراقبة الأنشطة والأحداث الأمنية.	Monitoring Activities	A.8.16
استخدام التشفير لحماية المعلومات والشهادات والمفاتيح عند انطباقه.	Use of Cryptography	A.8.24
فصل بيئات التطوير والاختبار والإنتاج.	Separation of Development, Test and Production Environments	A.8.31
إدارة واعتماد واختبار التغييرات.	Change Management	A.8.32
حماية معلومات الاختبار ومنع الاستخدام غير المنضبط للبيانات الحقيقية.	Test Information	A.8.33

6. إدارة الحوادث

عند اكتشاف حادث أمني أو خلل تشغيلي له تأثير على أمن المعلومات، يتم اتباع الخطوات التالية:

1. تحديد الحادث وتسجيل وقت اكتشافه.
2. إبلاغ SOC أو Information Security والجهات ذات العلاقة.
3. تقييم أثر الحادث وتحديد الأنظمة والبيانات المتأثرة.
4. تنفيذ إجراءات الاحتواء المناسبة.
5. المحافظة على السجلات والأدلة ذات الصلة.
6. تنفيذ المعالجة والاستعادة بالتنسيق مع مالك النظام.
7. توثيق السبب الجذري والإجراءات التصحيحية.
8. متابعة الدروس المستفادة وتحديث الإجراءات أو الضوابط عند الحاجة.

7. المراقبة والتدقيق

تتم مراقبة الالتزام بهذه الإجراءات من خلال مراجعة سجلات الوصول والتغييرات، ونتائج فحوصات Qualys، وحالة حماية الأجهزة باستخدام Trend Micro، وسجلات Syslog، وسجل الشهادات الرقمية، وتقارير الحوادث، ونتائج التدقيق الداخلي.

يتم استخدام نتائج المراقبة والتدقيق لتحديد حالات عدم المطابقة وفرص التحسين، واتخاذ الإجراءات التصحيحية المناسبة عند الحاجة.

8. مراجعة وتحديث

تتم مراجعة هذه الإجراءات مرة واحدة سنوياً على الأقل، وكذلك عند حدوث تغيير جوهري في البنية التحتية أو الأنظمة، أو بعد وقوع حادث أمني مهم، أو عند ظهور متطلبات تنظيمية جديدة، أو عند اكتشاف فجوة خلال عمليات التدقيق.

يجب توثيق كل مراجعة من خلال رقم الإصدار وتاريخ المراجعة والتغييرات التي تم إجراؤها والجهة المسؤولة عن الاعتماد.

9. المراجع

- ISO/IEC 27001:2022 – Annex A Control A.5.37, Documented Operating Procedures.
- ISO/IEC 27001:2022 – Annex A Controls A.5.15, A.5.18, A.8.2, A.8.8, A.8.9, A.8.11, A.8.15, A.8.16, A.8.24, A.8.31, A.8.32 and A.8.33.
- Digital Horizons Bank – ISO/IEC 27001:2022 ISMS Case Study.
- REQUIRED-R9 – Secure Configuration Baseline.
- REQUIRED-G12 – BCP & Disaster Recovery Plan.
- ISMS-DOC-09-5 – Internal Audit Report.